

TRƯỜNG ĐẠI HỌC VĂN HIẾN
KHOA CÔNG NGHỆ THÔNG TIN

BÁO CÁO TIỂU LUẬN CUỐI KỲ

HỌC PHẦN: BẢO MẬT IoT

TÊN ĐỀ TÀI

Nghe lén dữ liệu cảm biến trong mạng IoT

Sinh viên thực hiện :	Thi Võ Hoàng Huy
Mã số sinh viên :	231A010454
Lớp học phần :	INT4410
Giảng viên :	Hồ Nhật Minh

TP. HỒ CHÍ MINH, 2026

THÔNG TIN VÀ CAM KẾT NỘP BÀI

Tên đề tài	Nghe lén dữ liệu cảm biến trong mạng IoT
Mã đề tài	27
Sinh viên/Nhóm	Thi Võ Hoàng Huy - 231A010454
Repo GitHub	https://github.com/huytvh059/De_tai_27- Nghe_len_du_lieu_trong_mang_IoT
Bản báo cáo	231A010454_ThiVoHoangHuy_27_BaoCao.docx
Bản trình chiếu	231A010454_ThiVoHoangHuy_27_Slide.pptx
Sản phẩm chính	Demo MQTT 3 chế độ (cleartext/HMAC-SHA256/AES-256-GCM), bảng rủi ro nghe lén/sửa đổi/giả mạo, sơ đồ luồng bảo vệ dữ liệu
Ngày nộp	24/07/2026

Cam kết an toàn và học thuật

Tôi/chúng tôi cam kết toàn bộ thử nghiệm được thực hiện trong môi trường cục bộ, thiết bị thuộc quyền sở hữu hoặc dữ liệu giả lập/được phép; không quét, khai thác hay thu thập dữ liệu từ hệ thống thật. Báo cáo, mã nguồn và minh chứng là kết quả làm việc của cá nhân/nhóm; mọi nội dung kế thừa đều được trích dẫn rõ ràng. Repo không chứa secret, token, mật khẩu hoặc dữ liệu cá nhân thật.

- Họ tên người cam kết: Thi Võ Hoàng Huy
- Ngày cam kết: 17/07/2026

Chữ ký: 

MỤC LỤC

1. MỞ ĐẦU	1
1.1. Bối cảnh và lý do chọn đề tài	1
1.2. Phát biểu vấn đề.....	1
1.3. Mục tiêu.....	1
1.4. Đối tượng và phạm vi	1
1.5. Sản phẩm dự kiến và đóng góp	2
2. CƠ SỞ LÝ THUYẾT VÀ NGUỒN LIÊN QUAN	3
2.1. Kiến trúc, giao thức hoặc công nghệ nền	3
2.2. Khái niệm bảo mật liên quan.....	3
2.3. Chuẩn, tài liệu và công cụ GitHub	3
2.4. Công trình/giải pháp liên quan	4
3. PHƯƠNG PHÁP VÀ THIẾT KẾ	5
3.1. Phương pháp thực hiện	5
3.2. Kiến trúc/mô hình và luồng dữ liệu.....	5
3.3. Môi trường, công cụ và dữ liệu	6
3.4. Quy trình thực hiện.....	6
3.5. Giới hạn an toàn và đạo đức	7
4. TRIỂN KHAI VÀ SẢN PHẨM	8
4.1. Chuẩn bị môi trường.....	8
4.2. Thành phần sản phẩm	9
4.3. Kịch bản thử nghiệm/đánh giá.....	9
Kịch bản TC-01 — Truyền dữ liệu thô (cleartext)	10
Kịch bản TC-02 — Ký kèm HMAC với dữ liệu hợp lệ	11
Kịch bản TC-03 — HMAC phát hiện gói tin bị sửa.....	12
Kịch bản TC-04 — Mã hóa AES-256-GCM.....	13
Kịch bản TC-05 — AES-256-GCM phát hiện bản mã bị phá.....	14
Kịch bản TC-06 — Xác thực hợp lệ trên broker cục bộ.....	15
Kịch bản TC-07 — Chặn kết nối sai thông tin đăng nhập.....	16
Kịch bản TC-08 — Phân quyền ACL chặn ghi trái phép.....	16
4.4. Hướng dẫn chạy hoặc sử dụng sản phẩm	17
5. KẾT QUẢ VÀ THẢO LUẬN.....	17
5.1. Kết quả chính.....	17
5.2. Bảng tổng hợp kết quả.....	18

- 5.3. Đối chiếu mục tiêu..... 18
- 5.4. Hạn chế..... 18
- 6. ĐÁNH GIÁ BẢO MẬT 19
 - 6.1. Tài sản và dữ liệu cần bảo vệ 19
 - 6.2. Mối đe dọa và lỗ hổng 19
 - 6.3. Ma trận rủi ro..... 20
 - 6.4. Biện pháp giảm thiểu và ưu tiên 20
 - 6.5. Đánh giá an toàn sau xử lý 20
- 7. KẾT LUẬN VÀ HƯỚNG PHÁT TRIỂN..... 20
 - 7.1. Kết luận 20
 - 7.2. Hướng phát triển..... 21
- TÀI LIỆU THAM KHẢO 21
- PHỤ LỤC A. CẤU TRÚC REPO VÀ GÓI NỘP 22
- PHỤ LỤC B. NHẬT KÝ ĐÓNG GÓP 22
- PHỤ LỤC C. CHECKLIST TRƯỚC KHI NỘP..... 22

DANH MỤC TỪ VIẾT TẮT

STT	Từ viết tắt	Giải thích
1	IoT	Internet of Things - vạn vật kết nối Internet
2	MQTT	Message Queuing Telemetry Transport - giao thức publish/subscribe dùng trong đề tài
3	HMAC	Hash-based Message Authentication Code - mã xác thực thông điệp có khóa
4	AES-GCM	Advanced Encryption Standard - Galois/Counter Mode - mã hóa có xác thực tích hợp
5	TLS	Transport Layer Security - giao thức bảo mật tầng vận chuyển
6	ACL	Access Control List - danh sách kiểm soát quyền truy cập
7	TC	Test Case - ca kiểm thử hay kịch bản kiểm thử.

DANH MỤC BẢNG BIỂU

Bảng 2.1. Chuẩn, tài liệu và công cụ GitHub tham khảo	3
Bảng 3.1. Môi trường, công cụ và dữ liệu thử nghiệm.....	6
Bảng 3.2. Các bước quy trình thực hiện	6
Bảng 4.1. Thành phần sản phẩm.....	9
Bảng 5.1. Bảng tổng hợp kết quả các kịch bản kiểm thử	18
Bảng 6.1. Tài sản và dữ liệu cần bảo vệ	19
Bảng 6.2. Môi đe dọa và lỗ hổng.....	19
Bảng 6.3. Ma trận rủi ro	20

DANH MỤC HÌNH ẢNH

Hình 3.1. Kiến trúc mô hình lab và luồng đi của dữ liệu cảm biến (nguồn: tự vẽ)	5
Hình 3.2. Các cách gửi dữ liệu và thứ kẻ nghe lén thấy (nguồn: tự vẽ)	6
Hình 4.1. Mô hình triển khai thực nghiệm 2 máy: client trên Windows và broker Mosquitto trên máy ảo Ubuntu	8
Hình 4.2. Gửi data kịch bản cleartext — dữ liệu hiển thị dạng rõ.....	10
Hình 4.3. Nhận data kịch bản cleartext — dữ liệu hiển thị dạng rõ.	10
Hình 4.4. Log của broker trong kịch bản truyền cleartext.....	11
Hình 4.5. Gửi data kịch bản HMAC với dữ liệu hợp lệ.	11
Hình 4.6. Nhận data kịch bản HMAC với dữ liệu hợp lệ.....	12
Hình 4.7. Log của broker trong quá trình truyền dữ liệu kịch bản hmac.	12
Hình 4.8. Nhận data kịch bản HMAC phát hiện dữ liệu bị sửa.....	13
Hình 4.9. Log của broker trong quá trình truyền dữ liệu kịch bản hmac phát hiện gói tin bị sửa.....	13
Hình 4.10. Kịch bản AES-256-GCM — mã hóa và giải mã thành công.....	14
Hình 4.11. Log của broker trong quá trình truyền dữ liệu kịch bản Mã hóa AES-256-GCM.....	14
Hình 4.12. Kịch bản AES-256-GCM phát hiện ciphertext bị sửa.	15
Hình 4.13. Log của broker trong quá trình truyền dữ liệu kịch bản Mã hóa AES-256-GCM phát hiện bản mã bị phá.	15
Hình 4.14. Subscriber kết nối đến MQTT Broker cục bộ thành công, có xác thực username/password.	16
Hình 4.15. Publisher kết nối hợp lệ qua broker cục bộ có xác thực username/password.....	16
Hình 4.16. Broker từ chối kết nối do sai thông tin đăng nhập.....	16
Hình 4.17. Cơ chế ACL chặn thao tác ghi trái phép trên broker cục bộ.....	16
Hình 4.18. ... Denied PUBLISH from... 17	

PHIẾU XÁC ĐỊNH YÊU CẦU RIÊNG CỦA ĐỀ TÀI

Mã và tên đề tài	Đề tài số 27 - Nghe lén dữ liệu cảm biến trong mạng IoT
Hướng đề tài	D
Vấn đề bảo mật cốt lõi	Tài sản cần bảo vệ là dữ liệu cảm biến (nhiệt độ, độ ẩm, trạng thái thiết bị) và định danh thiết bị truyền qua MQTT. Nguy cơ chính là bị nghe lén khi payload truyền dạng cleartext, kèm theo nguy cơ sửa đổi dữ liệu và giả mạo thiết bị khi thiếu cơ chế toàn vẹn và xác thực.
Ba mục tiêu bắt buộc	(1) Minh họa bằng log/demo rằng payload MQTT cleartext bị đọc được khi nghe lén; (2) Triển khai và so sánh HMAC-SHA256, AES-256-GCM như biện pháp mã hóa/xác thực; (3) So sánh định lượng nội dung payload rõ và payload được bảo vệ qua 3 chế độ.
Sản phẩm/đầu ra bắt buộc	Code MQTT demo (publisher/subscriber/utils); Log payload dạng rõ và payload được bảo vệ; Bảng rủi ro nghe lén/sửa đổi/giả mạo; Sơ đồ luồng bảo vệ dữ liệu.
Nguồn GitHub/tool chính	De_tai_27-Nghe_len_du_lieu_trong_mang_IoT - https://github.com/huytvh059/De_tai_27-Nghe_len_du_lieu_trong_mang_IoT (nhánh main)
Minh chứng sẽ thu thập	Log cleartext/HMAC/AES-GCM, ảnh terminal publisher/subscriber, bảng rủi ro, mã nguồn, commit GitHub
Phạm vi an toàn	Lab cục bộ / broker công khai test.mosquitto.org, toàn bộ dữ liệu cảm biến là dữ liệu giả lập

1. MỞ ĐẦU

1.1. Bối cảnh và lý do chọn đề tài

Trong các hệ thống IoT hiện đại, thiết bị cảm biến (nhiệt độ, độ ẩm, trạng thái vận hành...) thường gửi dữ liệu định kỳ về gateway hoặc server thông qua giao thức MQTT do tính nhẹ, tiết kiệm băng thông và phù hợp với thiết bị tài nguyên hạn chế (OASIS, MQTT Version 5.0 Specification, 2019). Trong nhiều triển khai thực tế, đặc biệt ở mức thử nghiệm hoặc chi phí thấp, payload MQTT vẫn được truyền dưới dạng văn bản rõ (cleartext) mà không qua lớp bảo vệ TLS. Khi đó, bất kỳ thiết bị nào cùng phân đoạn mạng Wi-Fi công cộng hoặc LAN đều có thể bắt gói tin và đọc trực tiếp nội dung bản tin, bao gồm device_id, nhiệt độ, độ ẩm, vị trí hoặc trạng thái thiết bị (OWASP, IoT Security Verification Standard - ISVS, 2023).

Đối tượng chịu ảnh hưởng trực tiếp là người dùng sở hữu thiết bị IoT gia đình/công nghiệp nhỏ và đơn vị vận hành hệ thống giám sát, vì dữ liệu cảm biến bị lộ có thể tiết lộ thói quen sinh hoạt, tình trạng thiết bị hoặc tạo điều kiện cho các tấn công tiếp theo (sửa đổi dữ liệu, giả mạo thiết bị). Đề tài được thực hiện nhằm minh họa cụ thể rủi ro nghe lén này trên một mô hình MQTT thu nhỏ, từ đó đề xuất và kiểm chứng các biện pháp phòng chống tương ứng.

1.2. Phát biểu vấn đề

Tài sản cần bảo vệ là dữ liệu cảm biến (nhiệt độ, độ ẩm, trạng thái thiết bị) và định danh thiết bị (device_id) được trao đổi giữa publisher (thiết bị cảm biến giả lập) và subscriber (server/ứng dụng giám sát) qua kênh MQTT. Mỗi đe dọa chính là nghe lén (eavesdropping) khi payload truyền ở dạng cleartext; hai mối đe dọa liên quan là sửa đổi dữ liệu (tampering) khi gói tin không có cơ chế toàn vẹn, và giả mạo thiết bị (spoofing) khi broker không yêu cầu xác thực/ACL.

Hậu quả gồm: rò rỉ thông tin riêng tư và trạng thái thiết bị; sai lệch dữ liệu vận hành dẫn đến báo động giả hoặc quyết định điều khiển sai; nguy cơ thiết bị giả mạo làm nhiễu hệ thống. Khoảng trống mà đề tài xử lý: chưa có minh chứng thực nghiệm trực quan (log, ảnh chụp) so sánh mức độ lộ thông tin giữa ba phương án cleartext, HMAC-SHA256 và AES-256-GCM, nên đề tài xây dựng demo cụ thể để lấp khoảng trống này.

1.3. Mục tiêu

- Mục tiêu 1: Minh họa bằng thực nghiệm việc dữ liệu cảm biến MQTT truyền dạng cleartext có thể bị đọc trực tiếp khi bị nghe lén.
- Mục tiêu 2: Xây dựng demo publisher/subscriber bằng Python (thư viện Eclipse Paho MQTT) mô phỏng thiết bị cảm biến và server giám sát.
- Mục tiêu 3: So sánh ba chế độ truyền dữ liệu - cleartext, HMAC-SHA256 (toàn vẹn) và AES-256-GCM (bí mật + toàn vẹn) - thông qua log thực nghiệm.
- Mục tiêu 4: Phân tích các mối đe dọa liên quan (nghe lén, sửa đổi dữ liệu, giả mạo thiết bị, replay) và đề xuất biện pháp phòng chống tương ứng.

1.4. Đối tượng và phạm vi

Đối tượng nghiên cứu: giao thức MQTT (mô hình publish/subscribe) và dữ liệu cảm biến giả lập (nhiệt độ, độ ẩm, trạng thái thiết bị) trao đổi giữa publisher và subscriber. Phạm vi thực hiện: môi trường lab an toàn, dùng broker công khai test.mosquitto.org hoặc Mosquitto cài cục bộ, toàn bộ dữ liệu là dữ liệu mô phỏng (không thu thập từ thiết bị hoặc người dùng thật). Ba chế độ bảo vệ dữ liệu được triển khai và so sánh (cleartext, HMAC-SHA256, AES-256-GCM); ngoài ra đề tài triển khai và kiểm chứng cơ chế xác thực username/password kết hợp ACL ở tầng broker cục bộ. Thời gian thực hiện: 6 buổi theo tiến độ học phần Bảo mật IoT (INT4410).

Giới hạn pháp lý và đạo đức: đề tài không thực hiện tấn công vào hệ thống mạng thật, không nghe lén dữ liệu của bên thứ ba, và không triển khai trên thiết bị IoT vật lý đang sản xuất thực tế; mọi kịch bản tấn công (sửa đổi gói tin, giả mạo) đều được mô phỏng bằng tham số --simulate-attack trong mã nguồn tự viết.

1.5. Sản phẩm dự kiến và đóng góp

Sản phẩm kỹ thuật: mã nguồn Python (src/publisher.py, src/subscriber.py, src/utlis.py) triển khai ba chế độ cleartext/HMAC/AES-GCM; cấu hình Mosquitto (mosquitto.conf, aclfile, passwd); dữ liệu giả lập (dataset_gia_lap.csv, payload_mau.json).

Sản phẩm phân tích: bảng đánh giá rủi ro nghe lén/sửa đổi/giả mạo/replay, sơ đồ luồng bảo vệ dữ liệu (Mermaid). Các sản phẩm có thể tái sử dụng làm mẫu minh họa an toàn truyền thông MQTT cho các đề tài hoặc bài tập khác liên quan đến bảo mật giao thức publish/subscribe. Giá trị chính là minh chứng trực quan, định lượng được về hiệu quả của từng lớp bảo vệ dữ liệu.

2. CƠ SỞ LÝ THUYẾT VÀ NGUỒN LIÊN QUAN

2.1. Kiến trúc, giao thức hoặc công nghệ nền

Mô hình lab gồm ba thành phần: (1) Publisher giả lập thiết bị cảm biến (DHT22-SENSOR-001), sinh payload JSON gồm nhiệt độ, độ ẩm và device_id theo chu kỳ; (2) MQTT Broker (Eclipse Mosquitto, dùng broker công khai test.mosquitto.org hoặc bản cài cục bộ với cấu hình Username/Password và ACL) đóng vai trò trung chuyển bản tin theo topic `iot/sensor/data`; (3) Subscriber đóng vai trò server giám sát, nhận payload, kiểm tra cơ chế bảo vệ (HMAC hoặc AES-GCM) và ghi log.

Luồng dữ liệu tổng quát: Thiết bị cảm biến giả lập -> MQTT Broker -> Subscriber kiểm tra dữ liệu. Ranh giới tin cậy nằm giữa publisher/subscriber (do sinh viên kiểm soát) và đường truyền mạng công khai đi qua broker - đây là vị trí kẻ tấn công (nghe lén) được giả định có thể quan sát lưu lượng.

2.2. Khái niệm bảo mật liên quan

Bộ ba CIA (Confidentiality - Integrity - Availability) là khung tham chiếu chính: đề tài tập trung vào Confidentiality (chống nghe lén qua mã hóa AES-256-GCM) và Integrity (chống sửa đổi qua HMAC-SHA256 hoặc authentication tag của AES-GCM). HMAC-SHA256 (RFC 2104) là mã xác thực điệp điệp có khóa, cho phép subscriber kiểm tra dữ liệu có bị thay đổi trên đường truyền hay không. AES-256-GCM (NIST SP 800-38D) là thuật toán mã hóa đối xứng có xác thực tích hợp, vừa che giấu nội dung vừa phát hiện sửa đổi qua authentication tag.

Theo mô hình đe dọa STRIDE, ba mối đe dọa được xác định là Spoofing (giả mạo thiết bị khi broker không xác thực), Tampering (sửa đổi payload khi thiếu cơ chế toàn vẹn) và Information Disclosure (lộ dữ liệu khi truyền cleartext). Kiểm soát tương ứng: xác thực Username/Password kết hợp ACL ở tầng broker, HMAC-SHA256 hoặc AES-GCM ở tầng payload.

2.3. Chuẩn, tài liệu và công cụ GitHub

STT	Nguồn/repo	URL	Phần đã sử dụng	Ngày truy cập
1	Eclipse Mosquitto	https://github.com/eclipse-mosquitto/mosquitto	MQTT Broker dùng để dựng lab và cấu hình xác thực/ACL	17/07/2026
2	Eclipse Paho Python Client	https://github.com/eclipse-paho/paho.mqtt.python	Thư viện Python viết publisher/subscriber MQTT	17/07/2026
3	OWASP IoT Security Verification Standard (ISVS)	https://github.com/OWASP/IoT-Security-Verification-Standard-ISVS	Checklist kiểm tra bảo mật IoT ở mức truyền tải và dữ liệu	17/07/2026
4	RFC 2104 - HMAC	https://datatracker.ietf.org/doc/html/rfc2104	Cơ sở lý thuyết HMAC-SHA256 chống sửa đổi payload	17/07/2026
5	NIST SP 800-38D - AES-GCM	https://csrc.nist.gov/publications/detail/sp/800-38d/final	Cơ sở lý thuyết AES-GCM bảo vệ bí mật và toàn vẹn	17/07/2026

2.4. Công trình/giải pháp liên quan

Eclipse Mosquitto/Paho (2024) cung cấp broker và client MQTT chuẩn được đề tài kế thừa làm nền tảng lab; hạn chế là cấu hình bảo mật (username/password, ACL, TLS) không bắt buộc theo mặc định nên vẫn dễ triển khai sai. OWASP ISVS (2023) cung cấp checklist xác minh bảo mật giao tiếp IoT mà đề tài kế thừa để đối chiếu mức đáp ứng của từng chế độ truyền. Đề tài bổ sung lớp bảo vệ ở tầng payload (HMAC/AES-GCM) thay vì chỉ dựa vào TLS ở tầng vận chuyển, minh họa nguyên tắc phòng thủ nhiều lớp.

3. PHƯƠNG PHÁP VÀ THIẾT KẾ

3.1. Phương pháp thực hiện

Đề tài sử dụng phương pháp lab mô phỏng kết hợp kiểm thử theo kịch bản (scenario-based testing) và phân tích rủi ro ở tầng giao thức. Cụ thể gồm năm hướng tiếp cận sau:

- Xây dựng lab MQTT thu nhỏ gồm ba thành phần publisher – broker – subscriber để tái hiện đường đi thực tế của dữ liệu cảm biến, thay cho việc can thiệp vào hệ thống thật.
- Kiểm thử theo ba kịch bản bảo vệ tầng dần (cleartext, HMAC-SHA256 và AES-256-GCM) trên cùng một tập dữ liệu giả lập để so sánh khách quan mức độ lộ thông tin và khả năng phát hiện sửa đổi.
- Kiểm thử xác thực và phân quyền ở tầng broker: dựng broker Mosquitto cục bộ có username/password và ACL, kiểm chứng việc từ chối đăng nhập sai (Not authorized) và chặn ghi trái phép (Denied PUBLISH).
- Mô phỏng tấn công có kiểm soát bằng tham số --simulate-attack trong mã nguồn tự viết (sửa giá trị nhiệt độ với HMAC, phá hoại ciphertext với AES-GCM), tuyệt đối không tấn công hệ thống bên ngoài.
- Phân tích rủi ro theo mô hình STRIDE cho ba mối đe dọa Information Disclosure (nghe lén), Tampering (sửa đổi) và Spoofing (giả mạo), đối chiếu với checklist OWASP ISVS.

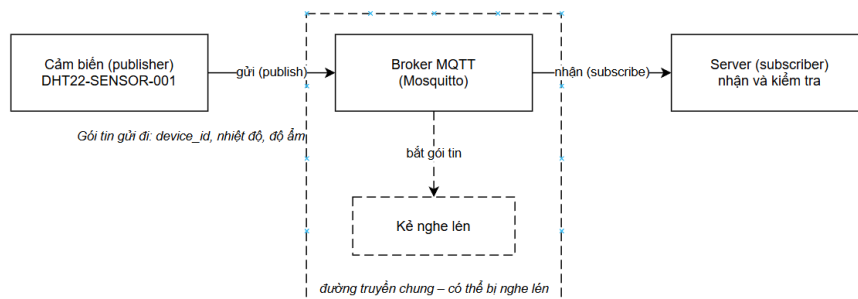
Kết quả mỗi kịch bản được thu thập tự động dưới dạng log (results/logs/) và bảng dữ liệu subscriber lưu lại (results/output.csv), bổ sung ảnh chụp màn hình làm minh chứng.

3.2. Kiến trúc/mô hình và luồng dữ liệu

Mô hình lab được minh họa ở Hình 3.1, gồm ba thành phần chính:

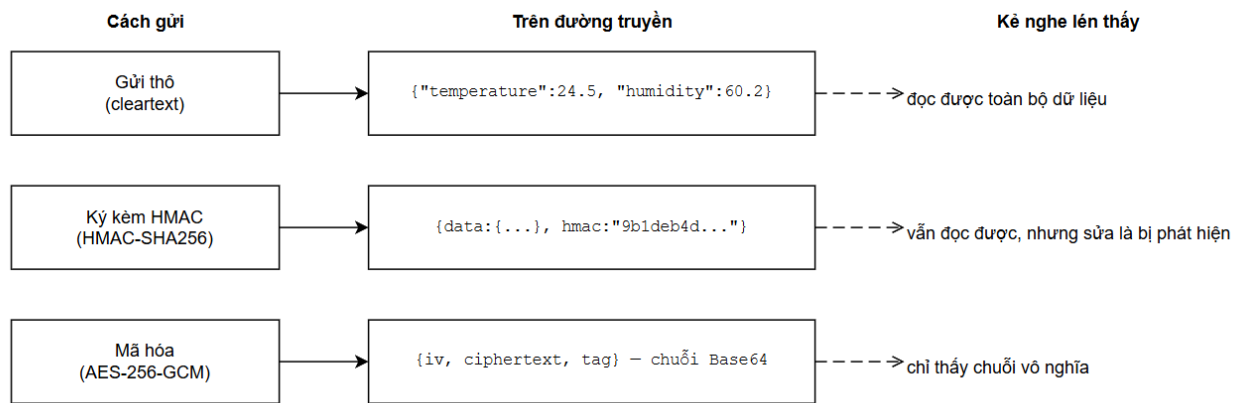
- Publisher – thiết bị cảm biến giả lập DHT22-SENSOR-001, đọc dữ liệu từ data/dataset_gia_lap.csv và sinh payload JSON gồm device_id, temperature, humidity, status theo chu kỳ.
- MQTT Broker – Eclipse Mosquitto, trung chuyển bản tin theo topic `iot/sensor/data`.
- Subscriber – server giám sát, nhận payload, kiểm tra cơ chế bảo vệ (HMAC hoặc AES-GCM) và ghi log.

Luồng dữ liệu tổng quát: Publisher → MQTT Broker → Subscriber. Ranh giới tin cậy (trust boundary) nằm giữa hai vùng: publisher và subscriber do sinh viên kiểm soát, còn broker và đường truyền mạng công khai nằm ngoài vùng tin cậy – đây là vị trí kẻ tấn công được giả định có thể quan sát lưu lượng và bắt gói tin. Dữ liệu nhạy cảm cần bảo vệ gồm device_id, temperature và humidity.



Hình 3.1. Kiến trúc mô hình lab và luồng đi của dữ liệu cảm biến (nguồn: tự vẽ)

Ba mức bảo vệ payload được so sánh ở Hình 3.2: cleartext (không bảo vệ), HMAC-SHA256 (chống sửa đổi) và AES-256-GCM (chống nghe lén và chống sửa đổi).



Hình 3.2. Các cách gửi dữ liệu và thứ kẻ nghe lén thấy (nguồn: tự vẽ)

3.3. Môi trường, công cụ và dữ liệu

Thành phần	Phiên bản	Mục đích	Ghi chú an toàn
Python	3.14	Ngôn ngữ chạy publisher/subscriber	Chạy cục bộ trên máy sinh viên
paho-mqtt	2.1.0	Thư viện client MQTT (Eclipse Paho)	Cài qua pip, không cần quyền admin
cryptography	49.0.0	Cung cấp mã hóa AES-256-GCM	Khóa chỉ dùng minh họa, không phải khóa thật
Eclipse Mosquitto	2.x / test.mosquitto.org	MQTT Broker: bản cục bộ cho kịch bản ACL, broker công khai để chạy nhanh	Bản cục bộ lắng nghe cổng 1883 trên mọi giao diện (0.0.0.0), allow_anonymous false, có xác thực và ACL
Máy ảo Ubuntu	24.04.4 LTS	Chạy broker Mosquitto cục bộ (xác thực + ACL)	Mạng nội bộ (Bridged/Host-only) với máy Windows, tách khỏi mạng thật
dataset_gia_lap.csv	—	Dữ liệu cảm biến giả lập (nhiệt độ, độ ẩm)	Hoàn toàn mô phỏng, không có dữ liệu thật

3.4. Quy trình thực hiện

Bước	Công việc	Đầu ra	Minh chứng trong repo
1	Cài môi trường (pip install paho-mqtt cryptography), chuẩn bị dữ liệu giả lập	Môi trường chạy được	data/dataset_gia_lap.csv

Bước	Công việc	Đầu ra	Minh chứng trong repo
2	Chạy kịch bản cleartext: publisher gửi JSON rõ, subscriber nhận	Dữ liệu đọc được trực tiếp trên đường truyền	results/logs/cleartext_traffic.log; ảnh cleartext_demo.png
3	Chạy kịch bản HMAC-SHA256 (thường và --simulate-attack)	Xác thực thành công / phát hiện sửa đổi	results/logs/secure_traffic.log; ảnh hmac_ok.png, hmac_attack.png
4	Chạy kịch bản AES-256-GCM (thường và --simulate-attack)	Ciphertext trên đường truyền / lỗi giải mã khi bị phá	ảnh aes_ok.png, aes_attack.png
5	Chạy kịch bản giả mạo/ACL trên broker Mosquitto cục bộ	Broker từ chối user/topic sai	TC-06→TC-08; results/screenshots/spoofing_blocked.png; results/logs/mosquitto.log
6	Tổng hợp log, lập bảng so sánh và ma trận rủi ro	Bảng kết quả, sơ đồ luồng	results/output.csv, README.md, Hình 3.1 và 3.2

3.5. Giới hạn an toàn và đạo đức

Đề tài tuân thủ nghiêm ngặt các giới hạn an toàn và đạo đức sau:

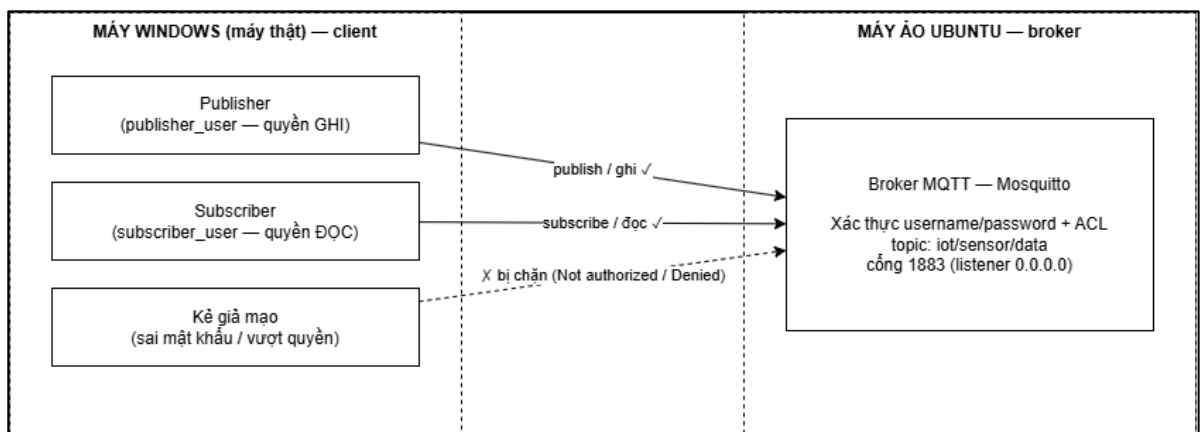
- Hệ thống được phép thử nghiệm: chỉ mô hình MQTT do sinh viên tự dựng (publisher, subscriber, broker cục bộ) hoặc broker công khai test.mosquitto.org với topic riêng của đề tài.
- Loại dữ liệu được dùng: hoàn toàn là dữ liệu cảm biến giả lập; không thu thập, không nghe lén dữ liệu của người dùng hoặc bên thứ ba.
- Xử lý secret: khóa HMAC/AES trong mã chỉ mang tính minh họa; repo không chứa mật khẩu, token hay dữ liệu cá nhân thật; file configs/passwd chỉ là mẫu, mật khẩu thật được sinh cục bộ bằng mosquitto_passwd và không commit.
- Hành động bị cấm: không quét hay tấn công hệ thống mạng thật, không triển khai trên thiết bị IoT đang vận hành thực tế; mọi kịch bản tấn công (sửa gói tin, giả mạo) đều được mô phỏng bằng tham số --simulate-attack trong môi trường cục bộ.

4. TRIỂN KHAI VÀ SẢN PHẨM

4.1. Chuẩn bị môi trường

Thực nghiệm sử dụng mô hình hai máy: một máy ảo Ubuntu đóng vai trò máy chủ trung gian (broker) chạy Eclipse Mosquitto cục bộ, và một máy Windows thật đóng vai trò các client gồm publisher, subscriber và máy giả mạo. Dữ liệu cảm biến được giả lập nên không cần thiết bị IoT vật lý. Các bước chuẩn bị như sau:

- Trên máy Windows: cài Python 3 và hai thư viện cần thiết bằng lệnh `pip install paho-mqtt cryptography`; tải mã nguồn từ repo về máy và giữ nguyên cấu trúc thư mục (src, configs, data, results).
- Trên máy ảo Ubuntu: cài Eclipse Mosquitto, sinh tài khoản bằng lệnh `mosquitto_passwd` và nạp cấu hình xác thực cùng danh sách phân quyền từ thư mục configs (mosquitto.conf, aclfile, passwd).
- Đặt hai máy trong cùng dải mạng nội bộ (chế độ Bridged hoặc Host-only, trong thực nghiệm là Bridged) để máy Windows kết nối tới broker qua địa chỉ IP của máy ảo trên cổng 1883.



Hình 4.1. Mô hình triển

khai thực nghiệm 2 máy: client trên Windows và broker Mosquitto trên máy ảo Ubuntu

+ Ở đây máy windows (máy thật) có địa chỉ IP như sau:

```
Wireless LAN adapter Wi-Fi:

Connection-specific DNS Suffix  . : 
Link-local IPv6 Address . . . . . : fe80::9808:5224:b7d4:35a7%19
IPv4 Address. . . . . : 192.168.1.2
Subnet Mask . . . . . : 255.255.255.0
Default Gateway . . . . . : 192.168.1.1
```

+ Máy Guest (VM- Ubuntu) có địa chỉ IP như sau:

```
2: ens33: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 00:0c:29:83:fb:f6 brd ff:ff:ff:ff:ff:ff
    altname enp2s1
    inet 192.168.1.6/24 metric 100 brd 192.168.1.255 scope global dynamic ens33
        valid_lft 3515sec preferred_lft 3515sec
    inet6 fe80::20c:29ff:fe83:fbf6/64 scope link
        valid_lft forever preferred_lft forever
```

Máy windows (client) đã kết nối với broker thành công:

```
PS C:\Users\USER> Test-NetConnection 192.168.1.6 -Port 1883

ComputerName      : 192.168.1.6
RemoteAddress     : 192.168.1.6
RemotePort        : 1883
InterfaceAlias    : Wi-Fi
SourceAddress     : 192.168.1.2
TcpTestSucceeded  : True
```

Máy windows (client) đã kết nối với broker thành công “TcpTestSucceeded”

Ban đầu ba kịch bản cơ bản (cleartext, HMAC, AES-GCM) được thử nhanh trên broker công khai test.mosquitto.org; tuy nhiên broker công khai không cho phép cấu hình xác thực và phân quyền, nên toàn bộ kịch bản — đặc biệt nhóm xác thực và ACL — được hoàn thiện trên broker Mosquitto cục bộ.

Chi tiết lệnh chạy được trình bày ở mục 4.4 và trong README của repo.

4.2. Thành phần sản phẩm

ST T	Thành phần	Đường dẫn repo	Chức năng	Người thực hiện
1	publisher.py	src/publisher.py	Giả lập cảm biến, gửi payload theo ba chế độ bảo vệ	Thi Võ Hoàng Huy
2	subscriber.py	src/subscriber.py	Nhận payload, kiểm tra HMAC/giải mã AES và ghi log	Thi Võ Hoàng Huy
3	utils.py	src/utils.py	Hàm HMAC-SHA256 và mã hóa AES-256-GCM	Thi Võ Hoàng Huy
4	Cấu hình Mosquitto	configs/mosquitto.conf, aclfile, passwd	Xác thực username/password và ACL cho broker cục bộ	Thi Võ Hoàng Huy
5	Dữ liệu giả lập	data/dataset_gia_lap.csv, payload_mau.json	Dữ liệu cảm biến và bản tin mẫu trước/sau bảo vệ	Thi Võ Hoàng Huy
6	Kết quả thực nghiệm	results/logs/, output.csv, screenshots/	Log, bảng dữ liệu nhận được và ảnh minh chứng	Thi Võ Hoàng Huy

4.3. Kịch bản thử nghiệm/đánh giá

Đề tài thực hiện tám kịch bản thử nghiệm, chia thành hai nhóm: Nhóm A bảo vệ dữ liệu ở mức bản tin (TC-01 đến TC-05) và Nhóm B xác thực, phân quyền ở tầng broker cục bộ (TC-06 đến TC-08). Mỗi kịch bản đều kèm ảnh chụp màn hình làm minh chứng.

Đầu tiên khởi động broker bằng lệnh nhập tại terminal: “**mosquitto -c configs/mosquitto.conf -v**”


```
huy@huy:~/De_tai_27-Nghe_len_du_lieu_trong_mang_IoT$ mosquitto -c configs/mosquitto.conf -v
1784899395: mosquitto version 2.0.18 starting
1784899395: Config loaded from configs/mosquitto.conf.
1784899395: Warning: File configs/aclfile has world readable permissions. Future versions will refuse to load this file.
To fix this, use `chmod 0700 configs/aclfile`.
1784899395: Opening ipv4 listen socket on port 1883.
1784899395: mosquitto version 2.0.18 running
1784899523: New connection from 192.168.1.2:62965 on port 1883.
1784899523: New client connected from 192.168.1.2:62965 as auto-D0C483B3-4F8C-E843-283C-014FCA298297 (p2, c1, k60, u'subscriber_user').
```

Tại máy windows mở sẵn 2 cửa sổ shell khác nhau đóng vai trò là publisher và subscriber.

Kịch bản TC-01 — Truyền dữ liệu thô (cleartext)

- Mục tiêu: chứng minh dữ liệu rõ bị lộ khi bị nghe lén
- Thao tác: chạy subscriber và publisher ở chế độ cleartext

Tại shell publisher gõ “py src\publisher.py --mode cleartext --broker 192.168.1.6 --username publisher_user --password 123 --topic iot/sensor/data” để gửi data ở chế độ cleartext.

```
PS C:\Users\USER> cd "D:\VHU\Tai_Lieu_Hoc_Phan\BAO_MAT_IOT\Bai_cuoi_ki"
PS D:\VHU\Tai_Lieu_Hoc_Phan\BAO_MAT_IOT\Bai_cuoi_ki> py src\publisher.py --mode cleartext --broker 192.168.1.6 --username publisher_user --password 123 --topic iot/sensor/data
[*] Đang kết nối tới MQTT Broker 192.168.1.6:1883...
[+] Đã kết nối thành công! Đang gửi dữ liệu ở chế độ [CLEARTEXT]...

[Gửi gói tin #1] Topic: iot/sensor/data
Payload gửi đi:
{"timestamp": "2026-07-09T15:40:00Z", "device_id": "DHT22-SENSOR-001", "temperature": 24.5, "humidity": 60.2, "status": "OK"}

[Gửi gói tin #2] Topic: iot/sensor/data
Payload gửi đi:
{"timestamp": "2026-07-09T15:40:05Z", "device_id": "DHT22-SENSOR-001", "temperature": 24.6, "humidity": 60.1, "status": "OK"}

[Gửi gói tin #3] Topic: iot/sensor/data
Payload gửi đi:
{"timestamp": "2026-07-09T15:40:10Z", "device_id": "DHT22-SENSOR-001", "temperature": 24.8, "humidity": 60.0, "status": "OK"}

[Gửi gói tin #4] Topic: iot/sensor/data
Payload gửi đi:
{"timestamp": "2026-07-09T15:40:15Z", "device_id": "DHT22-SENSOR-001", "temperature": 25.0, "humidity": 59.8, "status": "OK"}
```

Hình 4.2. Gửi data kịch bản cleartext — dữ liệu hiển thị dạng rõ.

Tại shell subscriber gõ “py src\subscriber.py --mode cleartext --broker 192.168.1.6 --username subscriber_user --password 123 --topic iot/sensor/data” để nhận data.

Ở đây có hiện cảnh báo data đang được truyền dưới dạng cleartext.

```
PS C:\Users\USER> cd "D:\VHU\Tai_Lieu_Hoc_Phan\BAO_MAT_IOT\Bai_cuoi_ki"
PS D:\VHU\Tai_Lieu_Hoc_Phan\BAO_MAT_IOT\Bai_cuoi_ki> py src\subscriber.py --mode cleartext --broker 192.168.1.6 --username subscriber_user --password 123 --topic iot/sensor/data
[*] Đang kết nối tới MQTT Broker 192.168.1.6:1883...
[+] Kết nối thành công! Đang subscribe tới topic: iot/sensor/data

=====
[*] Nhận bản tin mới lúc: 2026-07-24T20:26:06.910130
[*] Raw payload chụp được từ đường truyền MQTT:
{"timestamp": "2026-07-09T15:40:00Z", "device_id": "DHT22-SENSOR-001", "temperature": 24.5, "humidity": 60.2, "status": "OK"}
=====
[!] CẢNH BÁO: Dữ liệu đang được truyền dưới dạng RÕ (Cleartext)!
[+] Thiết bị ID: DHT22-SENSOR-001
[+] Nhiệt độ: 24.5°C | Độ ẩm: 60.2%
[*] Đã ghi nhận kết quả vào file: D:\VHU\Tai_Lieu_Hoc_Phan\BAO_MAT_IOT\Bai_cuoi_ki\results\output.csv

=====
[*] Nhận bản tin mới lúc: 2026-07-24T20:26:08.911259
[*] Raw payload chụp được từ đường truyền MQTT:
{"timestamp": "2026-07-09T15:40:05Z", "device_id": "DHT22-SENSOR-001", "temperature": 24.6, "humidity": 60.1, "status": "OK"}
=====
[!] CẢNH BÁO: Dữ liệu đang được truyền dưới dạng RÕ (Cleartext)!
[+] Thiết bị ID: DHT22-SENSOR-001
```

Hình 4.3. Nhận data kịch bản cleartext — dữ liệu hiển thị dạng rõ.

```

1784899566: New connection from 192.168.1.2:62806 on port 1883.
1784899566: New client connected from 192.168.1.2:62806 as auto-2C99882F-90E8-3BBC-25FC-FD96990F0693 (p2, c1, k60, u'publisher_user').
1784899566: No will message specified.
1784899566: Sending CONNACK to auto-2C99882F-90E8-3BBC-25FC-FD96990F0693 (0, 0)
1784899566: Received PUBLISH from auto-2C99882F-90E8-3BBC-25FC-FD96990F0693 (d0, q1, r0, m1, 'iot/sensor/data', ... (125 bytes))
1784899566: Sending PUBLISH to auto-D0C483B3-4F8C-E843-283C-014FCA298297 (d0, q0, r0, m0, 'iot/sensor/data', ... (125 bytes))
1784899566: Sending PUBACK to auto-2C99882F-90E8-3BBC-25FC-FD96990F0693 (m1, rc0)
1784899568: Received PUBLISH from auto-2C99882F-90E8-3BBC-25FC-FD96990F0693 (d0, q1, r0, m2, 'iot/sensor/data', ... (125 bytes))
1784899568: Sending PUBLISH to auto-D0C483B3-4F8C-E843-283C-014FCA298297 (d0, q0, r0, m0, 'iot/sensor/data', ... (125 bytes))
1784899568: Sending PUBACK to auto-2C99882F-90E8-3BBC-25FC-FD96990F0693 (m2, rc0)
1784899570: Received PUBLISH from auto-2C99882F-90E8-3BBC-25FC-FD96990F0693 (d0, q1, r0, m3, 'iot/sensor/data', ... (125 bytes))
1784899570: Sending PUBLISH to auto-D0C483B3-4F8C-E843-283C-014FCA298297 (d0, q0, r0, m0, 'iot/sensor/data', ... (125 bytes))
1784899570: Sending PUBACK to auto-2C99882F-90E8-3BBC-25FC-FD96990F0693 (m3, rc0)
1784899572: Received PUBLISH from auto-2C99882F-90E8-3BBC-25FC-FD96990F0693 (d0, q1, r0, m4, 'iot/sensor/data', ... (125 bytes))
1784899572: Sending PUBLISH to auto-D0C483B3-4F8C-E843-283C-014FCA298297 (d0, q0, r0, m0, 'iot/sensor/data', ... (125 bytes))
1784899572: Sending PUBACK to auto-2C99882F-90E8-3BBC-25FC-FD96990F0693 (m4, rc0)
1784899574: Received PUBLISH from auto-2C99882F-90E8-3BBC-25FC-FD96990F0693 (d0, q1, r0, m5, 'iot/sensor/data', ... (125 bytes))
1784899574: Sending PUBLISH to auto-D0C483B3-4F8C-E843-283C-014FCA298297 (d0, q0, r0, m0, 'iot/sensor/data', ... (125 bytes))
1784899574: Sending PUBACK to auto-2C99882F-90E8-3BBC-25FC-FD96990F0693 (m5, rc0)
1784899576: Received PUBLISH from auto-2C99882F-90E8-3BBC-25FC-FD96990F0693 (d0, q1, r0, m6, 'iot/sensor/data', ... (125 bytes))
1784899576: Sending PUBLISH to auto-D0C483B3-4F8C-E843-283C-014FCA298297 (d0, q0, r0, m0, 'iot/sensor/data', ... (125 bytes))

```

Hình 4.4. Log của broker trong kịch bản truyền cleartext.

- Kết quả quan sát: subscriber hiển thị JSON rõ, ai bắt gói tin cũng đọc được toàn bộ nhiệt độ và độ ẩm

Kịch bản TC-02 — Ký kèm HMAC với dữ liệu hợp lệ

- Mục tiêu: kiểm chứng tính toàn vẹn khi dữ liệu không bị sửa
- Thao tác: chạy chế độ hmac ở trạng thái bình thường

Tại shell publisher gõ “py src\publisher.py --mode hmac --broker 192.168.1.6 --username publisher_user --password 123 --topic iot/sensor/data” để gửi data bằng chế độ hmac

```

PS D:\VHU\Tai_Lieu_Hoc_Phan\BAO_MAT_IOT\Bai_cuoi_ki> py src\publisher.py --mode hmac --broker 192.168.1.6 --user
name publisher_user --password 123 --topic iot/sensor/data
[*] Đang kết nối tới MQTT Broker 192.168.1.6:1883...
[+] Đã kết nối thành công! Đang gửi dữ liệu ở chế độ [HMAC]...

[Gửi gói tin #1] Topic: iot/sensor/data
Payload gửi đi:
{"data": {"timestamp": "2026-07-09T15:40:00Z", "device_id": "DHT22-SENSOR-001", "temperature": 24.5, "humidity":
60.2, "status": "OK"}, "hmac": "0d3227730bdc71e2cc39fec64504e053858519137676195dbf1b759d6935e287"}

[Gửi gói tin #2] Topic: iot/sensor/data
Payload gửi đi:
{"data": {"timestamp": "2026-07-09T15:40:05Z", "device_id": "DHT22-SENSOR-001", "temperature": 24.6, "humidity":
60.1, "status": "OK"}, "hmac": "3b2e5c4f0bb9aa2a588d4b530b1e4b80e96b6b9f83b2808b51375aa527f8cfff8"}

[Gửi gói tin #3] Topic: iot/sensor/data
Payload gửi đi:
{"data": {"timestamp": "2026-07-09T15:40:10Z", "device_id": "DHT22-SENSOR-001", "temperature": 24.8, "humidity":
60.0, "status": "OK"}, "hmac": "2f499a2df372e0b6bd1f41f7b5f3ef6949923cd1a5f54c1e081b3ea4d47d4837"}

[Gửi gói tin #4] Topic: iot/sensor/data
Payload gửi đi:
{"data": {"timestamp": "2026-07-09T15:40:15Z", "device_id": "DHT22-SENSOR-001", "temperature": 25.0, "humidity":
59.8, "status": "OK"}, "hmac": "d46773856bce0ee0859d3fb7bc5eb108b982255a4a8149ea8446011d0c5f617a"}

```

Hình 4.5. Gửi data kịch bản HMAC với dữ liệu hợp lệ.

Tại shell subscriber gõ “py src\subscriber.py --mode hmac --broker 192.168.1.6 --username subscriber_user --password 123 --topic iot/sensor/data” để nhận data.

```
PS D:\VHU\Tai_Lieu_Hoc_Phan\BAO_MAT_IOT\Bai_cuoi_ki> py src\subscriber.py --mode hmac --broker 192.168.1.6 --username su
bscriber_user --password 123 --topic iot/sensor/data
[*] Đang kết nối tới MQTT Broker 192.168.1.6:1883...
[+] Kết nối thành công! Đang subscribe tới topic: iot/sensor/data

=====
[*] Nhận bản tin mới lúc: 2026-07-24T20:42:30.552358
[*] Raw payload chụp được từ đường truyền MQTT:
{"data": {"timestamp": "2026-07-09T15:40:00Z", "device_id": "DHT22-SENSOR-001", "temperature": 24.5, "humidity": 60.2, "
status": "OK"}, "hmac": "0d3227730bdc71e2cc39fec64504e053858519137676195dbf1b759d6935e287"}
=====
[+] XÁC THỰC HMAC THÀNH CÔNG: Dữ liệu toàn vẹn và đúng nguồn gốc!
[+] Thiết bị ID: DHT22-SENSOR-001
[+] Nhiệt độ: 24.5°C | Độ ẩm: 60.2%
[*] Đã ghi nhận kết quả vào file: D:\VHU\Tai_Lieu_Hoc_Phan\BAO_MAT_IOT\Bai_cuoi_ki\results\output.csv

=====
[*] Nhận bản tin mới lúc: 2026-07-24T20:42:32.558482
[*] Raw payload chụp được từ đường truyền MQTT:
{"data": {"timestamp": "2026-07-09T15:40:05Z", "device_id": "DHT22-SENSOR-001", "temperature": 24.6, "humidity": 60.1, "
status": "OK"}, "hmac": "3b2e5c4f0bb9aa2a588d4b530b1e4b80e96b6b9f83b2808b51375aa527f8cff8"}
=====
```

Hình 4.6. Nhận data kịch bản HMAC với dữ liệu hợp lệ.

- Kết quả quan sát: subscriber báo "XÁC THỰC HMAC THÀNH CÔNG"

```
huy@huy:~/De_tai_27-Nghe_len_du_lieu_trong_mang_IoT$ mosquitto -c configs/mosquitto.conf -v
1784900522: mosquitto version 2.0.18 starting
1784900522: Config loaded from configs/mosquitto.conf.
1784900522: Warning: File configs/aclfile has world readable permissions. Future versions will refuse to load this file.
To fix this, use 'chmod 0700 configs/aclfile'.
1784900522: Opening ipv4 listen socket on port 1883.
1784900522: mosquitto version 2.0.18 running
1784900537: New connection from 192.168.1.2:59176 on port 1883.
1784900537: New client connected from 192.168.1.2:59176 as auto-038DAA58-6CCC-89EC-E919-ED70B9640BE6 (p2, c1, k60, u'subscriber_user').
1784900537: No will message specified.
1784900537: Sending CONNACK to auto-038DAA58-6CCC-89EC-E919-ED70B9640BE6 (0, 0)
1784900537: Received SUBSCRIBE from auto-038DAA58-6CCC-89EC-E919-ED70B9640BE6
1784900537: iot/sensor/data (QoS 0)
1784900537: auto-038DAA58-6CCC-89EC-E919-ED70B9640BE6 0 iot/sensor/data
1784900537: Sending SUBACK to auto-038DAA58-6CCC-89EC-E919-ED70B9640BE6
1784900549: New connection from 192.168.1.2:59180 on port 1883.
1784900549: New client connected from 192.168.1.2:59180 as auto-258588F7-4CB7-317D-CF5A-B88BF2566D04 (p2, c1, k60, u'publisher_user').
1784900549: No will message specified.
1784900549: Sending CONNACK to auto-258588F7-4CB7-317D-CF5A-B88BF2566D04 (0, 0)
1784900549: Received PUBLISH from auto-258588F7-4CB7-317D-CF5A-B88BF2566D04 (d0, q1, r0, m1, 'iot/sensor/data', ... (211 bytes))
1784900549: Sending PUBLISH to auto-038DAA58-6CCC-89EC-E919-ED70B9640BE6 (d0, q0, r0, m0, 'iot/sensor/data', ... (211 bytes))
1784900549: Sending PUBACK to auto-258588F7-4CB7-317D-CF5A-B88BF2566D04 (m1, rc0)
1784900551: Received PUBLISH from auto-258588F7-4CB7-317D-CF5A-B88BF2566D04 (d0, q1, r0, m2, 'iot/sensor/data', ... (211 bytes))
1784900551: Sending PUBLISH to auto-038DAA58-6CCC-89EC-E919-ED70B9640BE6 (d0, q0, r0, m0, 'iot/sensor/data', ... (211 bytes))
1784900551: Sending PUBACK to auto-258588F7-4CB7-317D-CF5A-B88BF2566D04 (m2, rc0)
1784900553: Received PUBLISH from auto-258588F7-4CB7-317D-CF5A-B88BF2566D04 (d0, q1, r0, m3, 'iot/sensor/data', ... (211 bytes))
1784900553: Sending PUBLISH to auto-038DAA58-6CCC-89EC-E919-ED70B9640BE6 (d0, q0, r0, m0, 'iot/sensor/data', ... (211 bytes))
1784900553: Sending PUBACK to auto-258588F7-4CB7-317D-CF5A-B88BF2566D04 (m3, rc0)
1784900555: Received PUBLISH from auto-258588F7-4CB7-317D-CF5A-B88BF2566D04 (d0, q1, r0, m4, 'iot/sensor/data', ... (211 bytes))
1784900555: Sending PUBLISH to auto-038DAA58-6CCC-89EC-E919-ED70B9640BE6 (d0, q0, r0, m0, 'iot/sensor/data', ... (211 bytes))
1784900555: Sending PUBACK to auto-258588F7-4CB7-317D-CF5A-B88BF2566D04 (m4, rc0)
1784900557: Received PUBLISH from auto-258588F7-4CB7-317D-CF5A-B88BF2566D04 (d0, q1, r0, m5, 'iot/sensor/data', ... (211 bytes))
```

Hình 4.7. Log của broker trong quá trình truyền dữ liệu kịch bản hmac.

Kịch bản TC-03 — HMAC phát hiện gói tin bị sửa

- Mục tiêu: phát hiện dữ liệu bị thay đổi trên đường truyền
- Thao tác: chạy chế độ hmac với tham số --simulate-attack

Tại shell của publisher gõ “py src\publisher.py --mode hmac --broker 192.168.1.6 --username publisher_user --password 123 --topic iot/sensor/data”

```
PS D:\VHU\Tai_Lieu_Hoc_Phan\BAO_MAT_IOT\Bai_cuoi_ki> py src\publisher.py --mode hmac --broker 192.168.1.6 --user
name publisher_user --password 123 --topic iot/sensor/data
[*] Đang kết nối tới MQTT Broker 192.168.1.6:1883...
[+] Đã kết nối thành công! Đang gửi dữ liệu ở chế độ [HMAC]...

[Gửi gói tin #1] Topic: iot/sensor/data
Payload gửi đi:
{"data": {"timestamp": "2026-07-09T15:40:00Z", "device_id": "DHT22-SENSOR-001", "temperature": 24.5, "humidity":
60.2, "status": "OK"}, "hmac": "0d3227730bdc71e2cc39fec64504e053858519137676195dbf1b759d6935e287"}

[Gửi gói tin #2] Topic: iot/sensor/data
Payload gửi đi:
{"data": {"timestamp": "2026-07-09T15:40:05Z", "device_id": "DHT22-SENSOR-001", "temperature": 24.6, "humidity":
60.1, "status": "OK"}, "hmac": "3b2e5c4f0bb9aa2a588d4b530b1e4b80e96b6b9f83b2808b51375aa527f8cff8"}

[Gửi gói tin #3] Topic: iot/sensor/data
Payload gửi đi:
{"data": {"timestamp": "2026-07-09T15:40:10Z", "device_id": "DHT22-SENSOR-001", "temperature": 24.8, "humidity":
60.0, "status": "OK"}, "hmac": "2f499a2df372e0b6bd1f41f7b5f3ef6949923cd1a5f54c1e081b3ea4d47d4837"}
```

Tại shell của subscriber gõ “py src\subscriber.py --mode hmac --simulate-attack --broker 192.168.1.6 --username subscriber_user --password sub123 --topic iot/sensor/data”

```
PS D:\VHU\Tai_Lieu_Hoc_Phan\BAO_MAT_IOT\Bai_cuoi_ki> py src\subscriber.py --mode hmac --simulate-attack --broker 192.168
.1.6 --username subscriber_user --password 123 --topic iot/sensor/data
[*] Đang kết nối tới MQTT Broker 192.168.1.6:1883...
[+] Kết nối thành công! Đang subscribe tới topic: iot/sensor/data

=====
[*] Nhận bản tin mới lúc: 2026-07-24T20:59:39.745943
[*] Raw payload chụp được từ đường truyền MQTT:
{"data": {"timestamp": "2026-07-09T15:40:00Z", "device_id": "DHT22-SENSOR-001", "temperature": 24.5, "humidity": 60.2, "
status": "OK"}, "hmac": "0d3227730bdc71e2cc39fec64504e053858519137676195dbf1b759d6935e287"}
=====
[!] Tấn công giả lập: Đang sửa đổi giá trị nhiệt độ trong gói tin...
[-] XÁC THỰC HMAC THẤT BẠI: Phát hiện dữ liệu đã bị sửa đổi trái phép trên đường truyền!
[+] Thiết bị ID: DHT22-SENSOR-001
[+] Nhiệt độ: 99.9°C | Độ ẩm: 60.2%
[*] Đã ghi nhận kết quả vào file: D:\VHU\Tai_Lieu_Hoc_Phan\BAO_MAT_IOT\Bai_cuoi_ki\results\output.csv

=====
```

Hình 4.8. Nhận data kịch bản HMAC phát hiện dữ liệu bị sửa.

- Kết quả quan sát: subscriber báo "XÁC THỰC HMAC THẤT BẠI"

```
1784901578: New connection from 192.168.1.2:60137 on port 1883.
1784901578: New client connected from 192.168.1.2:60137 as auto-F622B09B-634D-965F-B632-0FBCC9ABF234 (p2, c1, k60, u'publisher_user').
1784901578: No will message specified.
1784901578: Sending CONNACK to auto-F622B09B-634D-965F-B632-0FBCC9ABF234 (0, 0)
1784901578: Received PUBLISH from auto-F622B09B-634D-965F-B632-0FBCC9ABF234 (d0, q1, r0, m1, 'iot/sensor/data', ... (211 bytes))
1784901578: Sending PUBLISH to auto-37FDFD2A-CE25-0459-F79F-3B2187266D7C (d0, q0, r0, m0, 'iot/sensor/data', ... (211 bytes))
1784901578: Sending PUBACK to auto-F622B09B-634D-965F-B632-0FBCC9ABF234 (m1, rc0)
1784901580: Received PUBLISH from auto-F622B09B-634D-965F-B632-0FBCC9ABF234 (d0, q1, r0, m2, 'iot/sensor/data', ... (211 bytes))
1784901580: Sending PUBLISH to auto-37FDFD2A-CE25-0459-F79F-3B2187266D7C (d0, q0, r0, m0, 'iot/sensor/data', ... (211 bytes))
1784901580: Sending PUBACK to auto-F622B09B-634D-965F-B632-0FBCC9ABF234 (m2, rc0)
1784901582: Received PUBLISH from auto-F622B09B-634D-965F-B632-0FBCC9ABF234 (d0, q1, r0, m3, 'iot/sensor/data', ... (211 bytes))
1784901582: Sending PUBLISH to auto-37FDFD2A-CE25-0459-F79F-3B2187266D7C (d0, q0, r0, m0, 'iot/sensor/data', ... (211 bytes))
1784901582: Sending PUBACK to auto-F622B09B-634D-965F-B632-0FBCC9ABF234 (m3, rc0)
1784901584: Received PUBLISH from auto-F622B09B-634D-965F-B632-0FBCC9ABF234 (d0, q1, r0, m4, 'iot/sensor/data', ... (211 bytes))
```

Hình 4.9. Log của broker trong quá trình truyền dữ liệu kịch bản hmac phát hiện gói tin bị sửa.

Kịch bản TC-04 — Mã hóa AES-256-GCM

- Mục tiêu: bảo vệ đồng thời bí mật và toàn vẹn dữ liệu
- Thao tác: chạy chế độ encrypted ở trạng thái bình thường

Tại shell của publisher gõ “py src\publisher.py --mode encrypted --broker 192.168.1.6 --username publisher_user --password 123 --topic iot/sensor/data”


```
PS D:\VHU\Tai_Lieu_Hoc_Phan\BAO_MAT_IOT\Bai_cuoi_ki> py src\publisher.py --mode encrypted --broker 192.168.1.6 --username publisher_user --password 123 --topic iot/sensor/data
[*] Đang kết nối tới MQTT Broker 192.168.1.6:1883...
[+] Đã kết nối thành công! Đang gửi dữ liệu ở chế độ [ENCRYPTED]...

[Gửi gói tin #1] Topic: iot/sensor/data
Payload gửi đi:
{"iv": "Cg9PiGLZ8wkljwms", "ciphertext": "PwbZ/Uay4as3Axd28e2u9JHmX1s96TgEOE7CM9AFo9yYcg3HnULL5H34Yf0JfLSBIeZ9jiH1buC5eSyugno1g2UHI8sk6+aoRK0aVi81niq0tjaGPi4vsSBH8wDT0mgzMp5LlNm1+vXH+IMZH6MezePni7gC2xNRKu+iAy0=", "tag": "s+HLZ0LRUgiHNggqd4zZdw==" }

[Gửi gói tin #2] Topic: iot/sensor/data
Payload gửi đi:
{"iv": "25muwa0wIPY0vq16", "ciphertext": "qp0qOI1qIIPFTfEmLs2P0roe6KSLmoo45FzoC7REy/MTA3h67cL4BbASUTdnf3+BoWUeBwzuStCT4yWKK1LS31uI1wSCfku7kE0DM6yN0sQaWn1V6l0GR1xkC1/gSyqIXrbCc1zeDP6AwG3HZ7zzh+SuS+ntsM0A1vnnGc=", "tag": "N+FVJyLExJ6vXLiG8j5BAG==" }
```

Tại shell của subscriber gõ “py src\subscriber.py --mode encrypted --broker 192.168.1.6 --username subscriber_user --password 123 --topic iot/sensor/data”

```
PS D:\VHU\Tai_Lieu_Hoc_Phan\BAO_MAT_IOT\Bai_cuoi_ki> py src\subscriber.py --mode encrypted --broker 192.168.1.6 --username subscriber_user --password 123 --topic iot/sensor/data
[*] Đang kết nối tới MQTT Broker 192.168.1.6:1883...
[+] Kết nối thành công! Đang subscribe tới topic: iot/sensor/data

=====
[*] Nhận bản tin mới lúc: 2026-07-24T21:12:35.449623
[*] Raw payload chụp được từ đường truyền MQTT:
{"iv": "Cg9PiGLZ8wkljwms", "ciphertext": "PwbZ/Uay4as3Axd28e2u9JHmX1s96TgEOE7CM9AFo9yYcg3HnULL5H34Yf0JfLSBIeZ9jiH1buC5eSyugno1g2UHI8sk6+aoRK0aVi81niq0tjaGPi4vsSBH8wDT0mgzMp5LlNm1+vXH+IMZH6MezePni7gC2xNRKu+iAy0=", "tag": "s+HLZ0LRUgiHNggqd4zZdw==" }
=====
[+] GIẢI MÃ THÀNH CÔNG: Dữ liệu được bảo vệ an toàn (Confidentiality & Integrity)!
[+] Thiết bị ID: DHT22-SENSOR-001
[+] Nhiệt độ: 24.5°C | Độ ẩm: 60.2%
[+] Đã ghi nhận kết quả vào file: D:\VHU\Tai_Lieu_Hoc_Phan\BAO_MAT_IOT\Bai_cuoi_ki\results\output.csv
```

Hình 4.10. Kịch bản AES-256-GCM — mã hóa và giải mã thành công.

- Kết quả quan sát: trên đường truyền chỉ là chuỗi ciphertext vô nghĩa, subscriber giải mã đúng dữ liệu gốc

```
1784902354: New connection from 192.168.1.2:51997 on port 1883.
1784902354: New client connected from 192.168.1.2:51997 as auto-AD9EEA67-FAE8-AA7A-36DE-BF839C4F940E (p2, c1, k60, u'publisher_user').
1784902354: No will message specified.
1784902354: Sending CONNACK to auto-AD9EEA67-FAE8-AA7A-36DE-BF839C4F940E (0, 0)
1784902354: Received PUBLISH from auto-AD9EEA67-FAE8-AA7A-36DE-BF839C4F940E (d0, q1, r0, m1, 'iot/sensor/data', ... (247 bytes))
1784902354: Sending PUBLISH to auto-BA0AEA31-F162-729E-0E2A-C908E54D26C1 (d0, q0, r0, m0, 'iot/sensor/data', ... (247 bytes))
1784902354: Sending PUBACK to auto-AD9EEA67-FAE8-AA7A-36DE-BF839C4F940E (m1, rc0)
1784902356: Received PUBLISH from auto-AD9EEA67-FAE8-AA7A-36DE-BF839C4F940E (d0, q1, r0, m2, 'iot/sensor/data', ... (247 bytes))
1784902356: Sending PUBLISH to auto-BA0AEA31-F162-729E-0E2A-C908E54D26C1 (d0, q0, r0, m0, 'iot/sensor/data', ... (247 bytes))
1784902356: Sending PUBACK to auto-AD9EEA67-FAE8-AA7A-36DE-BF839C4F940E (m2, rc0)
1784902358: Received PUBLISH from auto-AD9EEA67-FAE8-AA7A-36DE-BF839C4F940E (d0, q1, r0, m3, 'iot/sensor/data', ... (247 bytes))
1784902358: Sending PUBLISH to auto-BA0AEA31-F162-729E-0E2A-C908E54D26C1 (d0, q0, r0, m0, 'iot/sensor/data', ... (247 bytes))
1784902358: Sending PUBACK to auto-AD9EEA67-FAE8-AA7A-36DE-BF839C4F940E (m3, rc0)
```

Hình 4.11. Log của broker trong quá trình truyền dữ liệu kịch bản Mã hóa AES-256-GCM.

Kịch bản TC-05 — AES-256-GCM phát hiện bản mã bị phá

- Mục tiêu: phát hiện khi ciphertext bị can thiệp
- Thao tác: chạy chế độ encrypted với tham số --simulate-attack

Tại shell của publisher gõ “py src\publisher.py --mode encrypted --broker 192.168.1.6 --username publisher_user --password 123 --topic iot/sensor/data”

```
PS D:\VHU\Tai_Lieu_Hoc_Phan\BAO_MAT_IOT\Bai_cuoi_ki> py src\publisher.py --mode encrypted --broker 192.168.1.6 --username publisher_user --password 123 --topic iot/sensor/data
[*] Đang kết nối tới MQTT Broker 192.168.1.6:1883...
[+] Đã kết nối thành công! Đang gửi dữ liệu ở chế độ [ENCRYPTED]...

[Gửi gói tin #1] Topic: iot/sensor/data
Payload gửi đi:
{"iv": "JRZL23p+GglquQr", "ciphertext": "Zf4sQb0GqPXrzWnIN5JD5iWsmnTybuWNY8ry1/XppJNBpJ7WzrR+mw3YdZQTQL1jPdx+WusxhFBsgHquORjUfLv6CSFhh8cj7B9uP6tjrl8ETCMTDPtULTIzWR1+Kf0HdI1PleLVVreydP89xdLCwD4dftoyzkeK8cwkcI=", "tag": "WdsFZ03CwKlTVMi/0FXlVQ==" }

[Gửi gói tin #2] Topic: iot/sensor/data
Payload gửi đi:
{"iv": "T4FFfF30sni7vyh2d", "ciphertext": "Wjz/onc1bg0r3yJtNuQ7s+KUBKrm0n7u3jwTvIXWcu1R0UA2hA8H4KzpnnjSLpkrDq5gUs6kJPexVWVgLT/KjOWi9R50EVxbLLSGUZDlsvrZiPeovA3sBeCHDl0MXHw1hcZ9TqHpkKGHbrJUfNi913o+aimQ7MLEGgp+RI=", "tag": "WBE43z95s+CbVMJ2unKKWA==" }
```

Tại shell của subscriber gõ “py src\subscriber.py --mode encrypted --simulate-attack --broker 192.168.1.6 --username subscriber_user --password 123 --topic iot/sensor/data”

```
PS D:\VHU\Tai_Lieu_Hoc_Phan\BAO_MAT_IOT\Bai_cuoi_ki> py src\subscriber.py --mode encrypted --simulate-attack --broker 192.168.1.6 --username subscriber_user --password 123 --topic iot/sensor/data
[*] Đang kết nối tới MQTT Broker 192.168.1.6:1883...
[+] Kết nối thành công! Đang subscribe tới topic: iot/sensor/data

=====
[*] Nhận bản tin mới lúc: 2026-07-24T21:17:34.790533
[*] Raw payload chụp được từ đường truyền MQTT:
{"iv": "JRZL23p+GglquQr", "ciphertext": "Zf4sQb0GqPXrzWnIN5JD5iWsmnTybuWNY8ry1/XppJNBpJ7WzrR+mw3YdZQTQL1jPdx+WusxhFBsgHquORjUfLv6CSFhh8cj7B9uP6tjrl8ETCMTDPtULTIzWR1+Kf0HdI1PleLVVreydP89xdLCwD4dftoyzkeK8cwkcI=", "tag": "WdsFZ03CwKlTVMi/0FXlVQ==" }

=====
[!] Tấn công giả lập: Đang phá hoại chuỗi ciphertext mã hóa...
[-] LỖI GIẢI MÃ: Kề tấn công đã sửa đổi gói tin hoặc khóa không đúng! Chi tiết: Giải mã thất bại hoặc dữ liệu đã bị sửa đổi trái phép! Chi tiết:
[*] Đã ghi nhận kết quả vào file: D:\VHU\Tai_Lieu_Hoc_Phan\BAO_MAT_IOT\Bai_cuoi_ki\results\output.csv
```

Hình 4.12. Kịch bản AES-256-GCM phát hiện ciphertext bị sửa.

- Kết quả quan sát: subscriber báo "LỖI GIẢI MÃ" và không lấy được dữ liệu.

```
1784902653: New connection from 192.168.1.2:58968 on port 1883.
1784902653: New client connected from 192.168.1.2:58968 as auto-AC5CB423-1E49-EBBF-D8F5-1C9C71AD1738 (p2, c1, k60, u'publisher_user').
1784902653: No will message specified.
1784902653: Sending CONNACK to auto-AC5CB423-1E49-EBBF-D8F5-1C9C71AD1738 (0, 0)
1784902653: Received PUBLISH from auto-AC5CB423-1E49-EBBF-D8F5-1C9C71AD1738 (d0, q1, r0, m1, 'iot/sensor/data', ... (247 bytes))
1784902653: Sending PUBLISH to auto-57D68438-3B9C-AA7D-E985-484D4FB638AD (d0, q0, r0, m0, 'iot/sensor/data', ... (247 bytes))
1784902653: Sending PUBACK to auto-AC5CB423-1E49-EBBF-D8F5-1C9C71AD1738 (m1, rc0)
1784902655: Received PUBLISH from auto-AC5CB423-1E49-EBBF-D8F5-1C9C71AD1738 (d0, q1, r0, m2, 'iot/sensor/data', ... (247 bytes))
1784902655: Sending PUBLISH to auto-57D68438-3B9C-AA7D-E985-484D4FB638AD (d0, q0, r0, m0, 'iot/sensor/data', ... (247 bytes))
1784902655: Sending PUBACK to auto-AC5CB423-1E49-EBBF-D8F5-1C9C71AD1738 (m2, rc0)
1784902657: Received PUBLISH from auto-AC5CB423-1E49-EBBF-D8F5-1C9C71AD1738 (d0, q1, r0, m3, 'iot/sensor/data', ... (247 bytes))
1784902657: Sending PUBLISH to auto-57D68438-3B9C-AA7D-E985-484D4FB638AD (d0, q0, r0, m0, 'iot/sensor/data', ... (247 bytes))
1784902657: Sending PUBACK to auto-AC5CB423-1E49-EBBF-D8F5-1C9C71AD1738 (m3, rc0)
```

Hình 4.13. Log của broker trong quá trình truyền dữ liệu kịch bản Mã hóa AES-256-GCM phát hiện bản mã bị phá.

Ba kịch bản TC-06 đến TC-08 được thực hiện trên broker Mosquitto cục bộ (chạy trên máy ảo Ubuntu) đã bật xác thực username/password và danh sách kiểm soát truy cập (ACL) — những tính năng mà broker công khai không cho phép cấu hình. Broker được chạy ở chế độ hiển thị log chi tiết (mosquitto -c configs/mosquitto.conf -v) nhằm ghi nhận các sự kiện kết nối và từ chối.

Kịch bản TC-06 — Xác thực hợp lệ trên broker cục bộ

- Mục tiêu: xác nhận hệ thống hoạt động đúng khi client sử dụng tài khoản hợp lệ.
- Thao tác: chạy publisher với tài khoản publisher_user (quyền ghi) và subscriber với tài khoản subscriber_user (quyền đọc), cùng trở về broker cục bộ bằng --broker <IP_may_ao> kèm --username và --password.
- Kết quả quan sát: broker chấp nhận kết nối (gửi CONNACK trả mã 0), publisher gửi và subscriber nhận được dữ liệu bình thường.

```
PS D:\VHU\Tai_Lieu_Hoc_Phan\BAO_MAT_IOT\Bai_cuoi_ki> py src\subscriber.py --broker 192.168.1.6 --username subscriber_user --password 123 --mode cleartext --topic iot/sensor/data
[*] Đang kết nối tới MQTT Broker 192.168.1.6:1883...
[+] Kết nối thành công! Đang subscribe tới topic: iot/sensor/data
```

Hình 4.14. Subscriber kết nối đến MQTT Broker cục bộ thành công, có xác thực username/password.

```
PS C:\Users\USER> cd "D:\VHU\Tai_Lieu_Hoc_Phan\BAO_MAT_IOT\Bai_cuoi_ki"
PS D:\VHU\Tai_Lieu_Hoc_Phan\BAO_MAT_IOT\Bai_cuoi_ki> py src\publisher.py --broker 192.168.1.6 --username publisher_user --password 123 --mode cleartext --topic iot/sensor/data
[*] Đang kết nối tới MQTT Broker 192.168.1.6:1883...
[+] Đã kết nối thành công! Đang gửi dữ liệu ở chế độ [CLEARTEXT]...
```

Hình 4.15. Publisher kết nối hợp lệ qua broker cục bộ có xác thực username/password.

Kịch bản TC-07 — Chặn kết nối sai thông tin đăng nhập

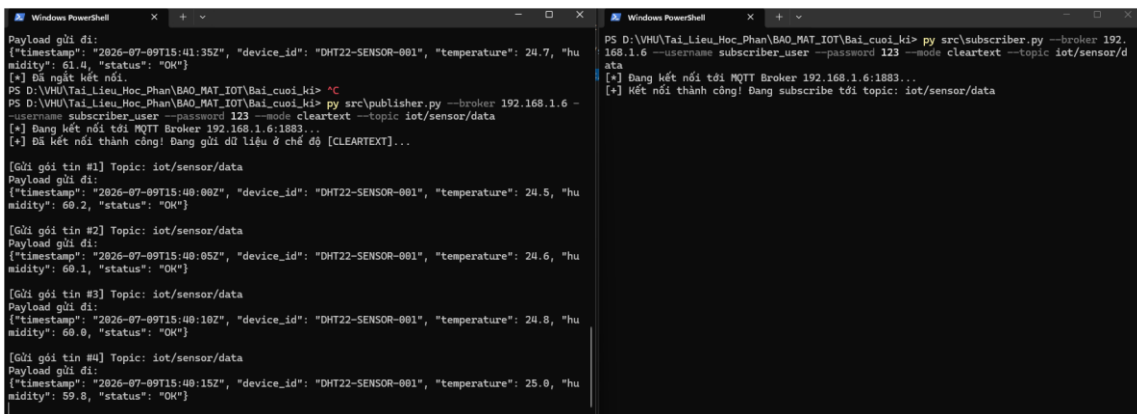
- Mục tiêu: chứng minh broker từ chối client không có tài khoản hợp lệ, chống giả mạo danh tính.
- Thao tác: chạy client với cặp username/password không hợp lệ để mô phỏng kẻ giả mạo. Ở đây nhập sai password. (Pass đúng là 123 như các ảnh trên nhưng em đã cố tình đặt sai pass là “saibet”).
- Kết quả quan sát: broker từ chối kết nối, client báo “Kết nối thất bại, mã trả về: Not authorized” và không có dữ liệu nào được trao đổi.

```
PS D:\VHU\Tai_Lieu_Hoc_Phan\BAO_MAT_IOT\Bai_cuoi_ki> py src\subscriber.py --broker 192.168.1.6 --username subscriber_user --password saibet --mode cleartext --topic iot/sensor/data
[*] Đang kết nối tới MQTT Broker 192.168.1.6:1883...
[-] Kết nối thất bại, mã trả về: Not authorized
[-] Kết nối thất bại, mã trả về: Not authorized
[-] Kết nối thất bại, mã trả về: Not authorized
[-] Kết nối thất bại, mã trả về: Not authorized
[*] Dừng subscriber.
[*] Đã ngắt kết nối.
PS D:\VHU\Tai_Lieu_Hoc_Phan\BAO_MAT_IOT\Bai_cuoi_ki>
```

Hình 4.16. Broker từ chối kết nối do sai thông tin đăng nhập.

Kịch bản TC-08 — Phân quyền ACL chặn ghi trái phép

- Mục tiêu: chứng minh cơ chế ACL ngăn tài khoản chỉ có quyền đọc thực hiện thao tác ghi, chống vượt quyền.
- Thao tác: dùng tài khoản subscriber_user (chỉ có quyền đọc) cố gắng publish lên topic iot/sensor/data.
- Kết quả quan sát: broker chấp nhận đăng nhập nhưng từ chối lệnh publish, ghi log Denied PUBLISH kèm mã lý do 135 (Not Authorized); subscriber hợp lệ không nhận được gói tin nào.



```
Windows PowerShell
Payload gửi đi:
{"timestamp": "2026-07-09T15:41:35Z", "device_id": "DHT22-SENSOR-001", "temperature": 24.7, "humidity": 61.4, "status": "OK"}
[*] Đã ngắt kết nối.
PS D:\VHU\Tai_Lieu_Hoc_Phan\BAO_MAT_IOT\Bai_cuoi_ki> cd "D:\VHU\Tai_Lieu_Hoc_Phan\BAO_MAT_IOT\Bai_cuoi_ki"
PS D:\VHU\Tai_Lieu_Hoc_Phan\BAO_MAT_IOT\Bai_cuoi_ki> py src\publisher.py --broker 192.168.1.6 --username subscriber_user --password 123 --mode cleartext --topic iot/sensor/data
[*] Đang kết nối tới MQTT Broker 192.168.1.6:1883...
[+] Đã kết nối thành công! Đang gửi dữ liệu ở chế độ [CLEARTEXT]...

[Gửi gói tin #1] Topic: iot/sensor/data
Payload gửi đi:
{"timestamp": "2026-07-09T15:40:00Z", "device_id": "DHT22-SENSOR-001", "temperature": 24.5, "humidity": 60.2, "status": "OK"}

[Gửi gói tin #2] Topic: iot/sensor/data
Payload gửi đi:
{"timestamp": "2026-07-09T15:40:05Z", "device_id": "DHT22-SENSOR-001", "temperature": 24.6, "humidity": 60.1, "status": "OK"}

[Gửi gói tin #3] Topic: iot/sensor/data
Payload gửi đi:
{"timestamp": "2026-07-09T15:40:10Z", "device_id": "DHT22-SENSOR-001", "temperature": 24.8, "humidity": 60.0, "status": "OK"}

[Gửi gói tin #4] Topic: iot/sensor/data
Payload gửi đi:
{"timestamp": "2026-07-09T15:40:15Z", "device_id": "DHT22-SENSOR-001", "temperature": 25.0, "humidity": 59.8, "status": "OK"}

Windows PowerShell
PS D:\VHU\Tai_Lieu_Hoc_Phan\BAO_MAT_IOT\Bai_cuoi_ki> py src\subscriber.py --broker 192.168.1.6 --username subscriber_user --password 123 --mode cleartext --topic iot/sensor/data
[*] Đang kết nối tới MQTT Broker 192.168.1.6:1883...
[+] Kết nối thành công! Đang subscribe tới topic: iot/sensor/data
```

Hình 4.17. Cơ chế ACL chặn thao tác ghi trái phép trên broker cục bộ.

Bên máy Guest (VM-Ubuntu) đóng vai trò broker, ta nhập lệnh “cat results/logs/mosquitto.log” để show ra log của broker ra màn hình.

```
1784871264: Sending CONNACK to auto-72F19391-B9FA-A4FE-892E-F980146D67AF (0, 0)
1784871264: Denied PUBLISH from auto-72F19391-B9FA-A4FE-892E-F980146D67AF (d0, q1, r0, m1, 'iot/sensor/data', ... (125 bytes))
1784871264: Sending PUBACK to auto-72F19391-B9FA-A4FE-892E-F980146D67AF (m1, rc135)
1784871266: Denied PUBLISH from auto-72F19391-B9FA-A4FE-892E-F980146D67AF (d0, q1, r0, m2, 'iot/sensor/data', ... (125 bytes))
1784871266: Sending PUBACK to auto-72F19391-B9FA-A4FE-892E-F980146D67AF (m2, rc135)
1784871268: Denied PUBLISH from auto-72F19391-B9FA-A4FE-892E-F980146D67AF (d0, q1, r0, m3, 'iot/sensor/data', ... (125 bytes))
1784871268: Sending PUBACK to auto-72F19391-B9FA-A4FE-892E-F980146D67AF (m3, rc135)
1784871270: Denied PUBLISH from auto-72F19391-B9FA-A4FE-892E-F980146D67AF (d0, q1, r0, m4, 'iot/sensor/data', ... (125 bytes))
1784871270: Sending PUBACK to auto-72F19391-B9FA-A4FE-892E-F980146D67AF (m4, rc135)
1784871272: Denied PUBLISH from auto-72F19391-B9FA-A4FE-892E-F980146D67AF (d0, q1, r0, m5, 'iot/sensor/data', ... (125 bytes))
1784871272: Sending PUBACK to auto-72F19391-B9FA-A4FE-892E-F980146D67AF (m5, rc135)
1784871274: Denied PUBLISH from auto-72F19391-B9FA-A4FE-892E-F980146D67AF (d0, q1, r0, m6, 'iot/sensor/data', ... (125 bytes))
1784871274: Sending PUBACK to auto-72F19391-B9FA-A4FE-892E-F980146D67AF (m6, rc135)
1784871276: Denied PUBLISH from auto-72F19391-B9FA-A4FE-892E-F980146D67AF (d0, q1, r0, m7, 'iot/sensor/data', ... (125 bytes))
1784871276: Sending PUBACK to auto-72F19391-B9FA-A4FE-892E-F980146D67AF (m7, rc135)
1784871276: Received DISCONNECT from auto-9620C074-E1A9-1DD8-A770-EDE1809A073A
1784871276: Client auto-9620C074-E1A9-1DD8-A770-EDE1809A073A disconnected.
1784871278: Denied PUBLISH from auto-72F19391-B9FA-A4FE-892E-F980146D67AF (d0, q1, r0, m8, 'iot/sensor/data', ... (130 bytes))
1784871278: Sending PUBACK to auto-72F19391-B9FA-A4FE-892E-F980146D67AF (m8, rc135)
1784871280: Received DISCONNECT from auto-72F19391-B9FA-A4FE-892E-F980146D67AF
1784871280: Client auto-72F19391-B9FA-A4FE-892E-F980146D67AF disconnected.
```

Hình 4.18. ... Denied PUBLISH from...

4.4. Hướng dẫn chạy hoặc sử dụng sản phẩm

Nhóm kịch bản bảo vệ dữ liệu cần hai cửa sổ terminal phía client: một chạy subscriber (bên nhận) và một chạy publisher (bên gửi), với tham số --mode trùng nhau.

- Bên nhận: python src/subscriber.py --mode cleartext
- Bên gửi: python src/publisher.py --mode cleartext
- Đổi --mode thành hmac hoặc encrypted để chạy hai chế độ còn lại; thêm --simulate-attack ở subscriber để kiểm chứng cơ chế phát hiện sửa đổi.
- Nhóm kịch bản xác thực và phân quyền dùng broker cục bộ: trên máy ảo Ubuntu chạy mosquitto -c configs/mosquitto.conf -v; trên máy Windows trở client tới broker bằng tham số --broker <IP_máy_ao> kèm --username và --password (ví dụ tài khoản publisher_user hoặc subscriber_user).

Điều kiện tái hiện: phía client có Python 3 với hai thư viện paho-mqtt và cryptography; phía máy chủ có một broker MQTT — broker công khai để thử nhanh, hoặc Mosquitto cục bộ có bật xác thực và ACL cho nhóm kịch bản nâng cao. Hướng dẫn đầy đủ nằm trong README của repo.

5. KẾT QUẢ VÀ THẢO LUẬN

5.1. Kết quả chính

Đề tài đã hoàn thành demo MQTT với ba chế độ bảo vệ dữ liệu và chạy được tám kịch bản thử nghiệm (năm kịch bản bảo vệ dữ liệu và ba kịch bản xác thực/phân quyền trên broker cục bộ). Các kết quả chính gồm:

- Ở chế độ cleartext, toàn bộ payload (device_id, nhiệt độ, độ ẩm) hiển thị dạng rõ trên đường truyền; log subscriber và ảnh chụp cho thấy dữ liệu bị đọc trực tiếp.
- Ở chế độ HMAC-SHA256, dữ liệu vẫn đọc được nhưng khi gói tin bị sửa, subscriber phát hiện ngay do chữ ký không khớp.
- Ở chế độ AES-256-GCM, dữ liệu trên đường truyền chỉ còn chuỗi Base64 vô nghĩa; khi ciphertext bị can thiệp, giải mã báo lỗi nhờ authentication tag.
- Ở tầng broker cục bộ, việc bật xác thực username/password và ACL đã chặn được kẻ giả mạo: sai thông tin đăng nhập bị từ chối kết nối (Not authorized), còn tài khoản chỉ có quyền đọc bị chặn khi cố ghi (Denied PUBLISH).

Kết quả cho thấy rõ sự khác biệt giữa ba mức bảo vệ dữ liệu, đồng thời chứng minh hiệu quả của cơ chế xác thực và phân quyền ở tầng broker — đúng như mục tiêu đề ra.

5.2. Bảng tổng hợp kết quả

Tiêu chí	Kỳ vọng	Kết quả thực tế	Đạt/Chưa đạt	Minh chứng
Bảo mật khi truyền thô	Dữ liệu rõ dễ bị lộ	Độc được toàn bộ JSON trên đường truyền	Đạt	cleartext_demo.png
Toàn vẹn (HMAC)	Phát hiện sửa đổi	Báo HMAC thất bại khi gói tin bị sửa	Đạt	hmac_attack.png
Bí mật (AES-GCM)	Che giấu nội dung	Đường truyền chỉ còn ciphertext	Đạt	aes_ok.png
Chống phá mã (AES tag)	Phát hiện ciphertext bị sửa	Báo lỗi giải mã khi bị can thiệp	Đạt	aes_attack.png
Ghi nhận dữ liệu	Lưu log và kết quả	Có log và output.csv cho các chế độ	Đạt	results/logs, output.csv
Xác thực broker	Chặn client không hợp lệ	Sai username/mật khẩu bị từ chối kết nối (Not authorized)	Đạt	TC-07 (Hình 4.16)
Phân quyền ACL	Chặn ghi trái phép	Tài khoản chỉ có quyền đọc bị chặn khi publish (Denied PUBLISH)	Đạt	spoofing_blocked (Hình 4.17)

5.3. Đối chiếu mục tiêu

Đối chiếu với bốn mục tiêu nêu ở Mục 1.3:

- Mục tiêu 1 (minh họa rủi ro cleartext): đạt — kịch bản TC-01 cho thấy dữ liệu rõ bị đọc trực tiếp.
- Mục tiêu 2 (demo publisher/subscriber bằng Paho): đạt — mã nguồn trong thư mục src chạy được trên broker thật.
- Mục tiêu 3 (so sánh ba chế độ): đạt — thể hiện qua bảng tổng hợp Mục 5.2 và log thực nghiệm.
- Mục tiêu 4 (phân tích đe dọa và biện pháp): đạt — trình bày ở Chương 6 và được kiểm chứng thực tế qua nhóm kịch bản xác thực/ACL (TC-06 đến TC-08).

5.4. Hạn chế

Đề tài còn một số hạn chế:

- Dữ liệu là giả lập, chưa lấy từ cảm biến vật lý thật.
- Kênh truyền chưa bật TLS ở tầng vận chuyển; dữ liệu mới được bảo vệ ở mức payload (HMAC/AES-GCM) và kiểm soát truy cập tại broker.
- Việc sửa đổi gói tin được mô phỏng bằng cờ --simulate-attack ở phía nhận, chưa phải tấn công xen giữa (MITM) thực tế trên đường truyền.

- Khóa HMAC/AES đặt trong mã nguồn nên chỉ phù hợp môi trường học tập, chưa có quản lý khóa an toàn.

6. ĐÁNH GIÁ BẢO MẬT

6.1. Tài sản và dữ liệu cần bảo vệ

Tài sản/dữ liệu	Chủ thể	Mức quan trọng	Yêu cầu C-I-A	Ghi chú
Dữ liệu cảm biến (nhiệt độ, độ ẩm)	Người dùng thiết bị	Cao	C, I	Lộ ra tiết lộ thói quen, tình trạng thiết bị
Định danh thiết bị (device_id)	Hệ thống giám sát	Trung bình	I, A	Bị giả mạo gây dữ liệu sai
Khóa HMAC/AES	Nhóm phát triển	Cao	C	Lộ khóa mất toàn bộ khả năng bảo vệ
Tài khoản broker (user/pass)	Quản trị broker	Cao	C, I	Lộ dẫn tới publish/subscribe trái phép
Log và dữ liệu nhận (output.csv)	Hệ thống giám sát	Trung bình	I	Dùng để phân tích, cần giữ toàn vẹn

6.2. Mối đe dọa và lỗ hổng

ID	Tài sản	Mối đe dọa	Lỗ hổng	Tác động	Minh chứng/nguồn
T-01	Dữ liệu cảm biến	Nghe lén (eavesdropping)	Payload truyền dạng cleartext	Lộ thông tin riêng tư	TC-01, OWASP ISVS
T-02	Dữ liệu cảm biến	Sửa đổi (tampering)	Thiếu cơ chế kiểm tra toàn vẹn	Dữ liệu sai lệch, báo động giả	TC-03, RFC 2104
T-03	Định danh thiết bị	Giả mạo (spoofing)	Broker không xác thực/ACL	Thiết bị giả gửi dữ liệu	TC-08, configs/aclfile
T-04	Dữ liệu cảm biến	Phát lại (replay)	Không kiểm tra timestamp/nonce	Gửi lại dữ liệu cũ	Phân tích STRIDE
T-05	Khóa HMAC/AES	Lộ khóa	Khóa hardcoded trong mã nguồn	Mất khả năng bảo vệ	src/utils.py
T-06	Tài khoản broker	Truy cập trái phép	Mật khẩu yếu hoặc dùng chung	Publish/subscribe trái phép	TC-07, configs/passwd

6.3. Ma trận rủi ro

ID	Khả năng (1-5)	Tác động (1-5)	Điểm	Mức rủi ro	Biện pháp	Rủi ro còn lại
R-01	4	4	16	Cao	Mã hóa AES-GCM hoặc bật TLS	Thấp
R-02	3	4	12	Cao	HMAC-SHA256 hoặc AES tag	Thấp
R-03	3	4	12	Cao	Username/password và ACL	Trung bình
R-04	2	3	6	Trung bình	Thêm timestamp/nonce	Trung bình
R-05	2	5	10	Cao	Quản lý khóa ngoài mã, xoay khóa	Trung bình
R-06	3	3	9	Trung bình	Mật khẩu mạnh, ACL tối thiểu	Thấp
Gợi ý: Có thể tính Điểm rủi ro = Khả năng × Tác động. Nêu rõ thang phân loại thấp, trung bình, cao và nghiêm trọng mà nhóm sử dụng.						

6.4. Biện pháp giảm thiểu và ưu tiên

Thứ tự ưu tiên biện pháp theo mức rủi ro:

- Ưu tiên cao: mã hóa AES-256-GCM ở payload (hoặc TLS ở tầng vận chuyển) để chống nghe lén và sửa đổi — chủ thể: nhóm phát triển, độ khó thấp.
- Ưu tiên cao: bật xác thực username/password và ACL trên broker để chống giả mạo — đã triển khai trên broker Mosquitto cục bộ và kiểm chứng qua TC-06 đến TC-08 (chủ thể: quản trị broker, độ khó trung bình).
- Ưu tiên trung bình: quản lý khóa ngoài mã nguồn (biến môi trường hoặc kho khóa) và xoay khóa định kỳ để chống lộ khóa.
- Ưu tiên trung bình: thêm timestamp/nonce vào payload để chống tấn công phát lại.

6.5. Đánh giá an toàn sau xử lý

Sau khi áp dụng mã hóa AES-GCM và bật xác thực cùng ACL trên broker cục bộ (đã kiểm chứng thực tế qua TC-06 đến TC-08), các rủi ro nghe lén, sửa đổi và giả mạo giảm xuống mức thấp. Rủi ro còn lại chủ yếu là quản lý khóa và tấn công phát lại, ở mức chấp nhận được trong phạm vi môi trường học tập. Nếu triển khai thực tế cần theo dõi và bổ sung: bật TLS, dùng kho khóa an toàn, và thêm cơ chế chống phát lại.

7. KẾT LUẬN VÀ HƯỚNG PHÁT TRIỂN

7.1. Kết luận

Đề tài đã xây dựng thành công một demo MQTT minh họa rõ rủi ro nghe lén dữ liệu cảm biến khi truyền dạng thô, kiểm chứng hai lớp bảo vệ dữ liệu HMAC-SHA256 và AES-256-GCM, đồng

thời triển khai xác thực và phân quyền (ACL) ở tầng broker cục bộ — tất cả qua tám kịch bản thử nghiệm có log và ảnh minh chứng. Kết quả cho thấy AES-GCM bảo vệ đồng thời tính bí mật và toàn vẹn, HMAC đảm bảo toàn vẹn khi cần giữ dữ liệu ở dạng đọc được, còn xác thực kết hợp ACL ngăn được truy cập và ghi trái phép trên broker. Bốn mục tiêu đề ra ở Mục 1.3 đều đạt; đề tài hoàn thành tốt phần thực nghiệm cốt lõi.

7.2. Hướng phát triển

Một số hướng phát triển tiếp theo:

- Bật TLS/SSL ở tầng vận chuyển (cổng 8883) để mã hóa toàn bộ kênh MQTT, bổ sung cho lớp bảo vệ payload và xác thực broker đã có.
- Đưa khóa ra khỏi mã nguồn, dùng biến môi trường hoặc kho khóa kèm cơ chế xoay khóa định kỳ.
- Thêm timestamp/nonce để chống tấn công phát lại (replay).
- Mở rộng với thiết bị và cảm biến thật (ESP32, Raspberry Pi) và nhiều loại dữ liệu hơn.

TÀI LIỆU THAM KHẢO

- [1] Eclipse Foundation. Eclipse Mosquitto. <https://github.com/eclipse-mosquitto/mosquitto>. Truy cập ngày 17/07/2026.
- [2] Eclipse Foundation. Eclipse Paho Python Client. <https://github.com/eclipse-paho/paho.mqtt.python>. Truy cập ngày 17/07/2026.
- [3] OWASP Foundation. IoT Security Verification Standard (ISVS). <https://github.com/OWASP/IoT-Security-Verification-Standard-ISVS>. Truy cập ngày 17/07/2026.
- [4] IETF. RFC 2104 - HMAC: Keyed-Hashing for Message Authentication. <https://datatracker.ietf.org/doc/html/rfc2104>. Truy cập ngày 17/07/2026.
- [5] NIST. SP 800-38D - Recommendation for Block Cipher Modes of Operation: Galois/Counter Mode (GCM). <https://csrc.nist.gov/publications/detail/sp/800-38d/final>. Truy cập ngày 17/07/2026.
- [6] OASIS. MQTT Version 5.0 Specification. <https://docs.oasis-open.org/mqtt/mqtt/v5.0/mqtt-v5.0.html>. Truy cập ngày 17/07/2026.

PHỤ LỤC A. CẤU TRÚC REPO VÀ GÓI NỘP

Đề tài 27_Nghe lén dữ liệu cảm biến trong mạng IoT/
 README.md
 report/
 slides/
 src/
 configs/
 data/
 results/
 references/

PHỤ LỤC B. NHẬT KÝ ĐÓNG GÓP

ST T	Họ tên - MSSV	Công việc	Commit/file	Tỷ lệ (%)	Xác nhận
1	Thi Võ Hoàng Huy – 231A010454	Nghiên cứu, soạn báo cáo, thiết kế lab, thực nghiệm	README, docs, report	100%	100%

PHỤ LỤC C. CHECKLIST TRƯỚC KHI NỘP

STT	Nội dung kiểm tra	Trạng thái
1	Báo cáo đủ 7 phần chính, mục lục và tài liệu tham khảo.	☒ Đạt ☐ Chưa đạt
2	Độ dài báo cáo chính 10-15 trang, không tính phụ lục.	☒ Đạt ☐ Chưa đạt
3	Repo mở được; README có cách chạy/sử dụng và mô tả cấu trúc.	☒ Đạt ☐ Chưa đạt
4	Có sản phẩm kỹ thuật hoặc sản phẩm phân tích hoàn chỉnh.	☒ Đạt ☐ Chưa đạt
5	Có ít nhất 3 minh chứng kiểm tra được trong results/ hoặc báo cáo.	☒ Đạt ☐ Chưa đạt
6	Có ít nhất 5 tài liệu tham khảo và repo GitHub/tool chính.	☒ Đạt ☐ Chưa đạt
7	Mọi hình/bảng có tên, số thứ tự, nguồn và phần phân tích.	☒ Đạt ☐ Chưa đạt
8	Không có secret, token, mật khẩu, dữ liệu cá nhân hoặc file nhạy cảm.	☒ Đạt ☐ Chưa đạt
9	Mọi thử nghiệm chỉ diễn ra trong môi trường local/được phép.	☒ Đạt ☐ Chưa đạt

STT	Nội dung kiểm tra	Trạng thái
10	Slide có 8-12 trang, link repo, kết quả chính, rủi ro và kết luận.	☒ Đạt ☐ Chưa đạt
11	Đã cập nhật mục lục, kiểm tra chính tả và xóa toàn bộ hướng dẫn mẫu.	☒ Đạt ☐ Chưa đạt